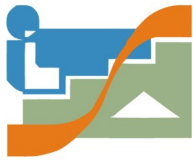


UNIT 03

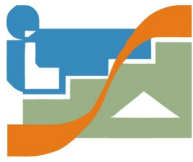
Cybersecurity Incidents

INVESTIGATION

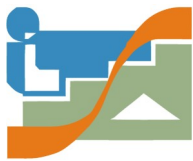




- **Collection of evidence**
- **Evidence analysis (risks)**
- **Investigation of the incident**
- **Exchange of information about the incident with suppliers or competent bodies**
- **Incident containment measures**



- **Collection of evidence**
- Evidence analysis (risks)
- Investigation of the incident
- Exchange of information about the incident with suppliers or competent bodies
- Incident containment measures



Collection of evidence

RFC 3227 - Guidelines for the collection of evidence and its storage



Principles during the collection of evidence

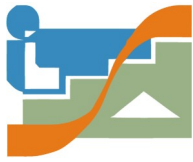
Collection procedure

The storage procedure

Necessary tools

<https://www.incibe-cert.es/blog/rfc3227>

<https://www.ciberforensic.com/directrices-rfc-3227>

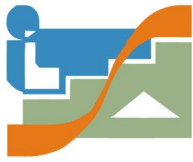


Collection of evidence

RFC 3227 - Guidelines for the collection of evidence and its storage

Principles during the collection of evidence

- Capture a system image as accurate as possible.
- Make detailed notes, including dates and times indicating whether local or UTC time is used.
- Minimize changes in the information being collected and eliminate external agents who can do so.
- In the case of facing a dilemma between collection and analysis choose first collection and then analysis.
- Collect the information according to the order of volatility (from highest to lowest).
- Keep in mind that for each device the collection of information can be done in a different way.



Collection of evidence

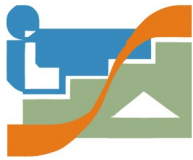
RFC 3227 - Guidelines for the collection of evidence and its storage

Principles during the collection of evidence - Volatility order

The volatility order refers to the time period in which certain information is accessible. That is why the information that will be available for the shortest period of time, that is to say, that whose volatility is greater, must be collected first.

According to this scale the following list can be created in order of highest to lowest volatility:

- Logs and cache contents.
- Routing table, ARP cache, process table, kernel statistics, memory.
- Temporary system information.
- Disc
- System logs.
- Physical configuration and network topology.
- Documents.



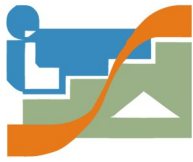
Collection of evidence

RFC 3227 - Guidelines for the collection of evidence and its storage

Principles during the collection of evidence - Actions that must be avoided

The following actions must be avoided in order not to invalidate the information collection process since its integrity must be preserved so that the results obtained can be used in a trial in the case that is necessary:

- Do not turn off the computer until all information has been collected.
- Do not rely on information provided by system programs as they may have been compromised. Information must be collected by programs from a protected medium as explained below.
- Do not run programs that modify the access date and time of all system files.

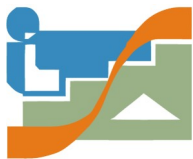


Collection of evidence

RFC 3227 - Guidelines for the collection of evidence and its storage

Principles during the collection of evidence - Privacy considerations

- It is very important to take into account the company's guidelines regarding privacy. It is usual to request a written authorization from the person concerned in order to carry out the collection of evidence. This is a fundamental aspect since it may be the case that you work with confidential or vitally important information for the company, or that the availability of services is affected.
- There is no need to intrude on people's privacy without justification. Data should not be collected from places where there is normally no reason to access, such as personal files, unless there is sufficient evidence.



Collection of evidence

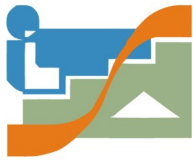
RFC 3227 - Guidelines for the collection of evidence and its storage

Collection procedure - Transparency

The methods used to collect evidence must be transparent and reproducible. You must be prepared to accurately reproduce the methods used, and that these methods have been tested by independent experts.

Steps

- Where is the evidence? List which systems are involved in the incident and from which of them evidence should be taken.
- Establish what is relevant. When in doubt it is better to collect a lot of information than a little.
- Set volatility order for each system.
- Obtain the information in accordance with the established order.
- Check the degree of synchronization of the system clock.
- As you go through the collection steps, ask yourself what else can be evidence.
- Document every step.
- Don't forget the people involved. Take notes on who people were there, what they were doing, what they observed and how they reacted.



Collection of evidence

RFC 3227 - Guidelines for the collection of evidence and its storage

The storage procedure

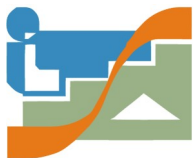
1. Chain of Custody

It must be clearly documented and the following points must be detailed:

- Where?, when? and who discovered and collected the evidence.
- Where?, when? and who tampered with the evidence.
- Who has guarded the evidence?, how long? and how did you store it?
- In the event that the evidence changes custody, indicate when and how the exchange was made, including the delivery note number, etc.

2. Where and how to store it

- The information must be stored in devices whose security has been demonstrated and which allow unauthorized access attempts to be detected.



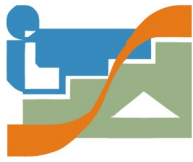
Collection of evidence

RFC 3227 - Guidelines for the collection of evidence and its storage

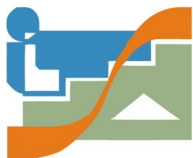
Necessary tools

There are a series of guidelines that must be followed when selecting the tools with which the collection process will be carried out:

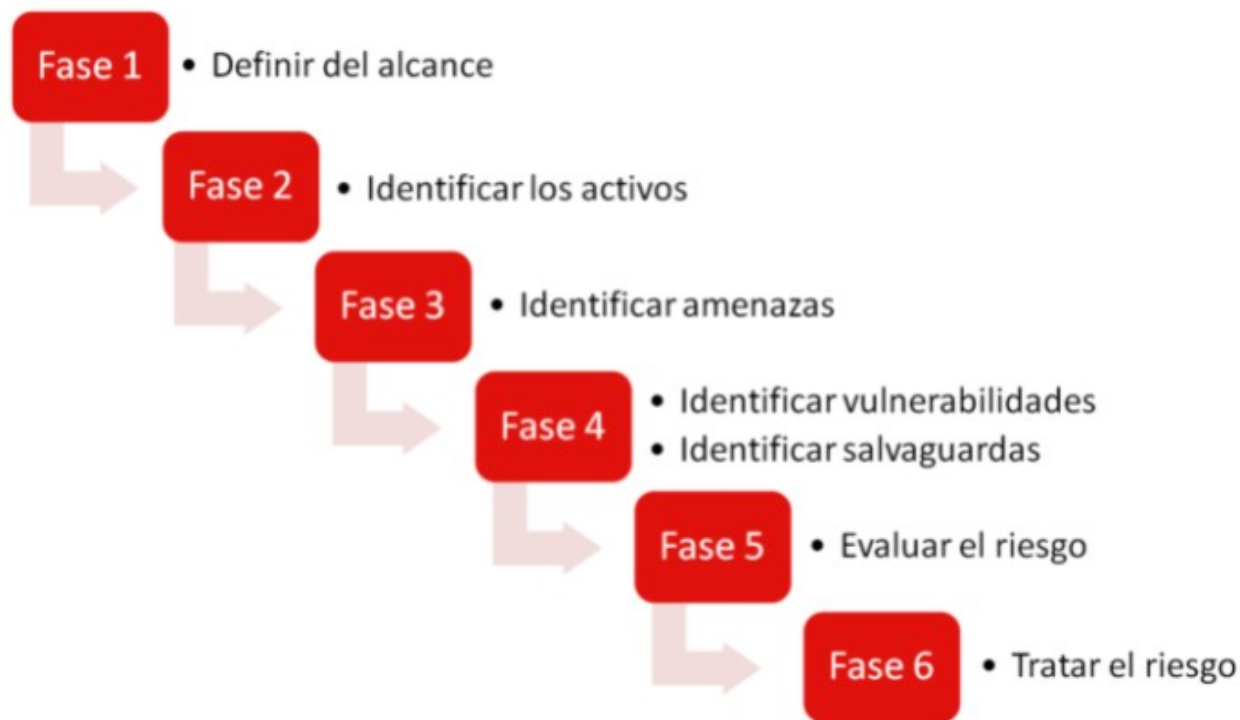
- Tools external to the system must be used as these may have been compromised, mainly in cases of malware.
- You must try to use tools that alter the scenario as little as possible, avoiding the use of graphical interface tools and those whose memory use is large.
- The programs that are going to be used to collect the evidence must be located on a read-only device (CDROM, protected pendrive, etc.).
- You must prepare a set of utilities appropriate to the operating systems with which you work.
- The analysis kit should include the following types of tools:
 - Programs for listing and examining processes.
 - Programs to examine the state of the system.
 - Programs to make bit by bit copies.



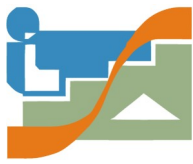
- Collection of evidence
- **Evidence analysis (risks)**
- Investigation of the incident
- Exchange of information about the incident with suppliers or competent bodies
- Incident containment measures



Evidence analysis (risks)



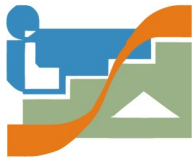
<https://www.incibe.es/protege-tu-empresa/blog/analisis-riesgos-pasos-sencillo>



Evidence analysis (risks)

Phase 1. Define the scope

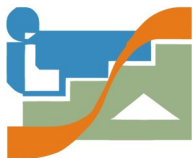
The first step in carrying out the risk analysis is to establish the scope of the study. We will consider this risk analysis to be part of the Security Master Plan. Therefore, we recommend that the risk analysis covers the entire scope of the PDS, where the strategic areas on which to improve security have been selected. On the other hand, it is also possible to define a more limited scope taking care of departments, processes or systems. For example, risk analysis on the processes of the Administration department, risk analysis on the production and warehouse management processes or risk analysis on the IT systems related to the company website, etc. In this practical case we consider that the scope chosen for the risk analysis is "The services and systems of the IT Department".



Evidence analysis (risks)

Phase 2. Identify the assets / equipment

Once the scope is defined, we must identify the most important assets that are related to the department, process, or system under study. To maintain a simple inventory of assets, it may be sufficient to use a spreadsheet or table.



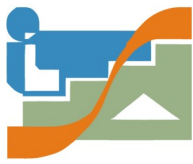
Evidence analysis (risks)

Phase 3. Identify / select the threats

Having identified the main assets, the next step is to identify the threats to which they are exposed. As we imagine, the set of threats is wide and diverse so we must make an effort to maintain a practical and applied approach. For example, if our intention is to assess the risk we run against the destruction of our file server, it is convenient to consider server failures, the possibility of water damage (broken pipe) or fire damage, instead of risking the CPD being destroyed by a meteorite.

https://administracionelectronica.gob.es/pae_Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html



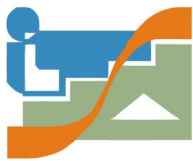


Evidence analysis (risks)

Phase 4. Identify vulnerabilities and safeguards

The next phase consists of studying the characteristics of our assets to identify weak points or vulnerabilities. For example, a potential vulnerability could be identifying a set of computers or servers whose anti-virus systems are not up-to-date or a series of assets that are not supported or maintained by the manufacturer. Subsequently, when assessing the risk we will apply penalties to reflect the identified vulnerabilities.

On the other hand, we will also analyze and document the security measures implemented in our organization. For example, we may have installed a UPS system (Uninterruptible Power Supply System) or a genset to supply electricity to CPD equipment. Both security measures (also known as safeguards) help reduce the risk of threats related to power outages.



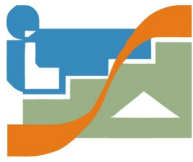
Evidence analysis (risks)

Phase 5. Assess / evaluate the risk

At this point we have the following elements:

- Asset inventory.
- Set of threats to which each asset is exposed.
- Set of vulnerabilities associated with each asset (if applicable).
- Set of implemented security measures

With this information, we are in a position to calculate the risk. For each asset-threat pair, we will estimate the likelihood that the threat will materialize and the business impact this would produce. The risk calculation can be performed using both quantitative and qualitative criteria.



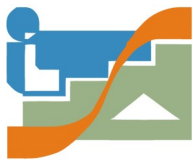
Evidence analysis (risks)

Phase 5. Assess / evaluate the risk

Risk calculation

When calculating the risk, if we have chosen to do the **quantitative** analysis, we will calculate by multiplying the probability and impact factors:

$RISK = PROBABILITY \times IMPACT$



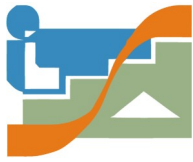
Evidence analysis (risks)

Phase 5. Assess the risk

Risk calculation

If, on the other hand, we have opted for **qualitative** analysis, we will use a risk matrix like the one shown below

		IMPACTO		
		Bajo	Medio	Alto
PROBABILIDAD	Baja	Muy bajo	Bajo	Medio
	Media	Bajo	Medio	Alto
	Alta	Medio	Alto	Muy alto

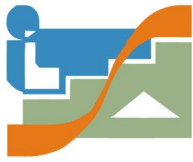


Evidence analysis (risks)

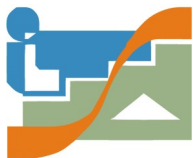
Phase 6. Deal with the risk

Once the risk has been calculated, we must deal with those risks that exceed a limit that we ourselves have established. For example, we will treat those risks whose value is higher than "4" or higher than "Average" if we have made the calculation in qualitative terms. When dealing with risk, there are four main strategies:

- Transfer the risk to a third party. For example, taking out insurance that covers damages to third parties caused by information leaks.
- Eliminate the risk. For example, removing a process or system that is subject to high risk. In the practical case that we have presented, we could remove the complimentary Wi-Fi to serve customers if it is not strictly necessary.
- Take the risk, always justifiably. For example, the cost of installing a generator set may be too high and therefore the organization may choose to assume.
- Implement measures to mitigate it. For example, hiring a backup internet access to be able to access services in the cloud in case the main line has gone down.

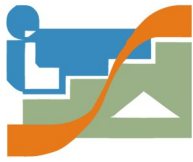


- Collection of evidence
- Evidence analysis (risks)
- **Investigation of the incident**
- Exchange of information about the incident with suppliers or competent bodies
- Incident containment measures



With forensic analysis techniques

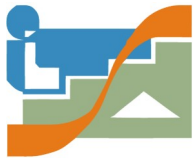




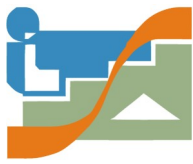
Forensic analysis

Each case will mean analysing some evidence

- **Communications**
- **Disk image**
- **Memory image**
- **Files with various formats**
- **Metadata**
- **Hardware devices**
- **Malware**



- Collection of evidence
- Evidence analysis (risks)
- Investigation of the incident
- Exchange of information about the incident with suppliers or competent bodies
- Incident containment measures



Suppliers -> with email

Competent organizations

- The affected subject will send an email (or ticket) to the reference CSIRT
- The reference CSIRT, depending on the incident, brings it to the attention of the receiving body involved or the competent national authority
 - If it affects National Defence, to ESP DEF CERT Mando Conjunto del Ciberespacio
 - If it affects Critical Infrastructure of the PIC Law 8/2011, to the CNPIC
 - If it affects the RGPD, to the AEPD.
 - If it is an AAPP incident under the ENS of VERY HIGH or CRITICAL danger, to the CCN-CERT
 - If it is a mandatory reporting incident according to RD Law 12/2018, to the corresponding competent national authority.
 - RGPD: the URL of the **AEPD** portal is sent.
 - **BDE**: BDE notification template .XLS is forwarded.
 - PIC: **CNPIC** .XLS notification template is forwarded.
 - ENS: The notification template .DOC is forwarded to **CCN-CERT**.
 - NIS: The national competent authority notification template is forwarded.



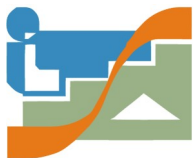
CNPIC
CENTRO NACIONAL DE PROTECCIÓN
DE INFRAESTRUCTURAS CRÍTICAS



REAL DECRETO 43/2021:
DESARROLLO NORMATIVO DE
CIBERSEGURIDAD EN ESPAÑA
(DIRECTIVA NIS)

[incibe: national-guidelines-reporting-and-managing-cyber-incidents](#)



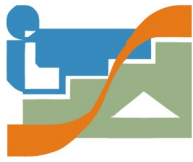


- The receiving body involved or competent national authority contacts the affected subject to collect data on the incident.
- The affected subject communicates the necessary data to the receiving body involved or competent national authority.
- If applicable, from the Office of Cyber Coordination (OCC, dependent on CNPIC) the information is made available to the State Security Forces and Bodies and the Public Prosecutor's Office to initiate the police and judicial investigation (art. 14.3 RD Law 12/2018).

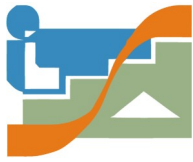
With the publication of RD 43/2021, critical operators, essential service operators and digital service providers have the obligation to notify their incidents.

Directive NIS – RD-L 12/2019 - RD 43/2021
https://www.incibe-cert.es/FAQ-RD_43-2021





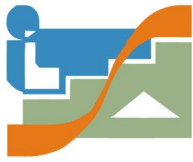
- Collection of evidence
- Evidence analysis (risks)
- Investigation of the incident
- Exchange of information about the incident with suppliers or competent bodies
- Incident containment measures



Once a cyber incident has been identified, the highest priority is to contain its impact on the organization so that the **spread** to other systems or networks can be avoided as soon as possible, avoiding a greater impact, and the **extraction** of information outside the organization.

This is usually the phase in which **triage** is carried out, which consists of evaluating all the information available at that moment and carrying out a classification and prioritization of the cyber incident based on the type and criticality of the information and systems affected.

In addition, possible impacts on the business are identified and, depending on the procedures, work is done on decision-making with the appropriate business units and/or those responsible for the services.



Mitigation measures will depend on the type of cyber incident, since in some cases it will be necessary to have the **support of service providers**, as in the case of a distributed denial of service (DDoS) attack, and in other cyber incidents it may mean including **full wipe of affected systems and recovery from backup**.

The purpose of the recovery phase is to return the level of operation to its normal state and that the affected business areas can resume their activity. It is important **not to rush or hurry** to put into production of systems that have been involved in cyber incidents.

Pay special attention to these systems during production and look for any signs of suspicious activity, defining a period of time with additional monitoring measures.